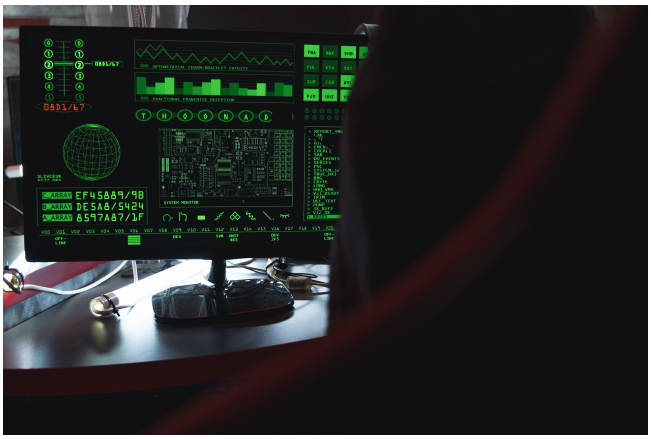


# SECURITY-X ASSIGNMENT

EDUV12936584

ITVXA0-44

Formative Assessment

EDUV12936584


ABSTRACT

CompTIA SecurityX is an advanced, expert-level cybersecurity certification formerly known as the CompTIA Advanced Security Practitioner (CASP+). Rebranded in December 2024 with exam code CAS-005, it validates hands-on technical skills for senior security architects and engineers.



Branny Aurthur Branfield

Security Architecture

# Question 1

## Scenario 1

### a. One of ABCTech's options is to offload anti-malware and anti-spam scanning to a cloud provider. What are some of the benefits and drawbacks of relying on cloud hash matching for these services?

Some Benefits and drawbacks of relying on cloud hash matching involve a comparison of unique cryptographic signatures also known as hashes for files, emails etc. in real-time updated cloud databases to instantly detect known threat against massive attacks.

Benefits

With cloud based signature processing minimising local resource consumption.

Cloud Databases provide real time global threat intelligence, instantly protecting ABCTech from new threats.

And with ABCTech avoiding to store large malware signature directories locally avoiding cost of purchasing and managing Server Machines for storage.

And Lastly with Hash matching being fast and accurate for known treats meaning it has high accuracy.

## Drawbacks

Hash matching fails to detect zero-day exploits, new malware, and targeted attacks meaning its inability to detect zero-day exploits still makes it vulnerable.

Cloud systems require stable internet connectivity for optimal performance having network dependency and effectiveness failure due to latency.

Additional Sending files or metadata hashes to a third-party cloud provider may raise privacy concerns.

And lastly Attackers being able to bypass hash matching by altering a single bit of non-executable code.

## b. How can a cloud-based sandbox help ABCTech test its internally developed applications?

A Cloud-based sandbox secures virtual environment by execution and observation of the behaviour of ABCTech's custom software without risking the corporate production network by providing an isolated environment.

As unsafe code execution is limited to cloud instance with cloud-based simulation enabling developers to create diverse, resource intensive testing environments safely with sandbox monitor application behaviour tracking registry changes, network calls, and file access.

With an additional benefit of a Testing Environment that can be destroyed and reconstructed in seconds.

## c. What situations can you think of that could warrant cloud content filtering for ABCTech?

Situations I can think of that could warrant cloud content filtering for ABCTech. Include cloud content filtering interception on web traffic to block malicious, inappropriate, or policy-violating websites before they reach ABCTech endpoints. To warrant this I would involve cloud-based filtering by providing universal security policies for employees, regardless of location.

Blocking access to phishing domains and malicious servers, preventing data exfiltration and phishing.

ABCTech restricting access to illegal, audit, or high-risk content to maintain a professional workplace and prevent legal liability.

And lastly Bandwidth preservation restricting access to non-business critical activities ensuring network stability.

## Scenario 2

### a. From a security perspective, briefly explain the purpose of the hashes in a blockchain.

The purpose of the hashes in a blockchain when involving security perspective are the abilities of cryptographic hashes functioning as unique, immutable digital fingerprints that secure data continuity and guarantees data integrity in a blockchain.

As Hashing algorithms create unique fixed-length strings for financial data, ensuring data integrity with unique identification of block content.

With new blocks containing the cryptographic hashes of the previous block, creating a chronological chain for data reliability and integrity by linking blocks through hashes, resulting in any altercation in a block being invalidated by the entire chain, making unauthorised changes easily detectable.

## b. How can a blockchain assist in the compliance audits that ABCTech finances are subject to?

Blockchain can assist in the compliance audits that ABCTech finances are subject to with blockchain being able to streamline and audit the process by creating a permanent, verifiable and single source of truth for ABCTech's global financials.

Blockchain ensures immutability of financial records providing auditors with assurance of data integrity with help of Historical Data.

Automated audit trails providing a chronological lifecycle of financial reports, reducing reconciliation time.

With Auditors being able to audit a single, unified system reflecting on global activities due to shared ledger state across regional nodes.

## c. How can the decentralised nature of the blockchain further guarantee the integrity of ABCTech's financial records?

The Decentralised nature of the blockchain can further guarantee the integrity of ABCTech financial records by shifting control from a single control server to a distributed network of nodes, removing single points of failure or manipulation.

So Decentralised blockchain eliminates the risk of a single point of attack, unlike a centralised database.

Decentralisation with regional nodes validates with an agreement on financial records before committing them, Performing a Consensus Mechanism.

With a 51% attack, requiring control of over a half of the nodes in a global network, which is logistically and financially impractical.

# Question 2

## Scenarios

### 1. What are some of the important factors to consider when choosing security standards to implement in the enterprise?

Some important factors to consider when choosing security standards for enterprise implementation is managing how well evaluated the framework aligns with both operational requirements and the existing threat landscape.

With standard meeting industry specific legal mandates such as PCI-DSS for Payments, HIPAA for Healthcare, or GDPR for Data Privacy with Regulatory and Compliance Requirements.

The Framework must support corporate objectives and integrate with existing ERM policies. For Business and Strategic Alignment.

Adding that chosen standards need to address industry-specific vulnerabilities, assets and threats with Threat Landscape and Risk Profile.

As organisation must consider financial budget, personnel skills and time required for framework adaption and maintenance with implementation cost and resource availability.

And the standard having to be scalable and flexible to accommodate enterprise growth and technology change.

2. As an Information Security Officer of Delware Inc., you have updated the security standards to meet enterprise risk management (ERM) requirements. With these standards in mind, what sort of interoperability issues might there be in legacy systems?

When having updated Security Standards to meet Enterprise Risk Management (ERM) requirements. Expectations often create friction with legacy architecture which include Interoperability issues including Legacy Systems using outdated cryptographic protocols and not supporting modern encryption methods such as (e.g. TLS 1.0, SSLv3, or 3DES) being incompatible Cipher Suite and Protocols.

As older software's may lack standard integration interface, hindering automated identification governance, Lacking Native API or Integration Support.

Legacy application often lack support for modern authentication standards like SAML,OIDC and MFA,

As well as outdated systems with hardcoded credentials and rigid architecture being vulnerable to updates in password policies.

And finally with Legacy Infrastructure lacking standardised text log and detailed auditing capabilities having Log Incompatibility and Format Mismatches.

## 3. Assuming Delware Inc. acquires a smaller competitor; how might this bring additional risk to the organisation from a personal standpoint?

When assuming that Delware inc. is acquiring a smaller competitor it can result in bringing in new personnel and absorbing their operational habits which can introduce distinct internal risk.
From a personal / human standpoint these risk include Disgruntled employees from acquired companies posing a higher risk of data exfiltration or sabotage as an Insider Threat and Cultural Friction.

Adding that smaller company's may have a relaxed security culture posing risk to newly absorbed staff.

With employees being vulnerable to phishing attacks disguised as HR updates during organisational restructuring involving Social Engineering and Phishing Vulnerabilities.

Or Uncontrolled (BYOD) Bring Your Own Device possibly allowing malware access as infected personal devices connect to Delware inc.'s network due to Device Contamination from Personnel's.

Lastly absorbed staff causes a temporary spike in accidental policy violators due to unfamiliarity with Delware inc.'s security baselines.

4. Five years ago, Delware Inc. purchased and deployed a network IDS from one vendor. The company purchased multiple types of host-based IPSes over a period of two years from a second vendor. Just recently, they purchased a brand new SIEM appliance from a third vendor. To improve its data collection, analysis and reporting processes, the organisation wants the SIEM to correlate and aggregate data from the IDS/IPS solutions. This should, overall, improve its resiliency in the face of threats. However, what issues or obstacles to this resilience tactic do you see?

With the issues and obstacles involved in this resilience tactic, Attempting to aggregate data across a heterogeneous environment containing a 5 year old network IDS, multiple host-based IPSes from different vendors, and a brand new SIEM introduce a significantly architectural roadblocks. As primary issues and obstacles including:

SIEM Integration challenges arise from incompatible log formats and lack of normalisation for diverse IDS and IPS products.

Time synchronisation and Drift Discrepancies such as time drift or unsynchronised NTP configurations, can cause discrepancies in event correlation with a SIEM.

Security platforms from different vendors often lack interoperability due to proprietary APIs and restricted access, hindering direct pipeline ingestions. With Vendor Lock-in and Closed Ecosystems.

Combining legacy network IDS with disjointed host-based IPSes leading to high alert volumes and false positives, overwhelming SIEM analytics and analysts.

With a 5 year old network IDS may having been outdated and unable to handle modern traffic or receive updates, impacting the data it provides to the new SIEM with End-of-Life (EOL) or outdated signatures on IDS Legacy Systems.

Network and host-based security solutions have different contextual viewpoints, requiring complex correlation rules for effective SIEM integration.